

The Phone Boss ULTD — Information Security Risk Summary

Assessment scope: repair, refurbishment, sales, technical support and online business operations. Advisory services remain prelaunch.

Current residual-risk profile	
Rating	Risk count
Low	1
Medium	6
High	3
Critical	0

Residual risk heat map (number of risks)					
Likelihood / Impact	1	2	3	4	5
	0	0	0	0	0
	0	0	0	0	0
	0	0	2	2	0
	0	0	2	2	1
	0	0	0	1	0

Risk location key					Portfolio interpretation Three current risks remain High: critical-account compromise, mixed personal/business device use, and inadequate incident response. Six risks are Medium and require maintained controls or planned treatment. The prelaunch advisory-services risk is Low because launch is being avoided until minimum governance is complete. Residual acceptance remains the responsibility of Richard Vincent as owner. Insurance may transfer part of the financial impact, but it does not transfer risk ownership. Scores should be reviewed after major business, technology, supplier, staffing, or incident changes.
Risk ID	Risk title	Current residual	Treatment	Status	
R-01	Customer device loss or theft	Medium	Accept and monitor	Ongoing	
R-02	Critical business account compromise	High	Mitigate	Planned	
R-03	Owner unavailability and single-person dependency	Medium	Mitigate	Planned	
R-04	Mixed personal and business device use	High	Mitigate	Planned	
R-05	Website loss or failed migration	Medium	Mitigate	In progress	
R-06	Temporary customer passcode exposure	Medium	Accept and monitor	Ongoing	
R-07	Inadequate incident response	High	Mitigate	Planned	
R-08	Cloud or payment-provider outage	Medium	Mitigate and partially transfer	Ongoing	
R-09	Payment fraud or account misuse	Medium	Mitigate and partially transfer	Ongoing	
R-10	Advisory services launched without minimum governance	Low	Avoid until ready	Not launched	

Rating thresholds	
Score	Rating
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Editable inputs are likelihood, impact, treatment, owner, planned actions, target ratings, status, and review evidence. Calculated scores and ratings update automatically.																					
Risk ID	Risk title	Asset / process	Risk statement	Inherent likelihood	Inherent impact	Inherent score	Inherent rating	Existing controls	Residual likelihood	Residual impact	Residual score	Residual rating	Treatment	Risk owner	Planned actions	Target likelihood	Target impact	Target score	Target rating	Status	Review trigger / evidence
R-01	Customer device loss or theft	Customer device handling	Because a customer device may be lost or stolen while in The Phone Boss ULTD's custody, an unauthorized person could obtain the device, resulting in customer-data exposure, replacement or reimbursement costs, complaints, and reputational harm.	3	4	12	High	Documented intake and authorization; secure handling and storage; sole-operator access; temporary passcodes destroyed after testing; most devices returned the same day.	2	4	8	Medium	Accept and monitor	Richard Vincent	Record devices kept overnight and the reason; maintain current custody controls.	2	4	8	Medium	Ongoing	Intake record, custody record, return receipt; review after loss, storage change, higher volume, or adding workers.
R-02	Critical business account compromise	Zoho, Cloudflare, GitHub, Stripe and other critical accounts	Because password uniqueness, recovery methods, active sessions, third-party integrations, and phishing-resistant authentication have not yet been fully verified, an attacker could compromise a critical business account, resulting in unauthorized transactions, data exposure, service disruption, and loss of administrative control.	3	4	12	High	MFA is enabled across critical business accounts.	3	4	12	High	Mitigate	Richard Vincent	Verify unique passwords and recovery methods; review active sessions and integrations; remove unnecessary access; strengthen MFA where available.	2	4	8	Medium	Planned	Password-manager review, recovery-method screenshots or exports, session review, integration inventory, MFA configuration evidence.
R-03	Owner unavailability and single-person dependency	Business continuity	Because the business depends on one owner and has no documented continuity arrangement, illness or another prolonged absence could prevent customer communication, completion or return of active repairs, and access to essential records, resulting in service interruption and customer dissatisfaction.	3	3	9	Medium	The owner retains direct knowledge of active jobs and business systems.	3	3	9	Medium	Mitigate	Richard Vincent	Create secure emergency instructions, an active-device and job inventory, customer-contact steps, and trusted-person authorization without informal password sharing.	2	3	6	Medium	Planned	Continuity procedure, emergency contact authorization, active-job inventory, secure access-recovery instructions.
R-04	Mixed personal and business device use	Owner laptop, phone and business access	Because personal and business activity occurs on the same devices, compromise or loss of a device could expose business accounts and customer information, resulting in unauthorized access, data exposure, and interruption of operations.	3	5	15	High	PIN/password or biometric access; device encryption; automatic updates; antivirus or endpoint protection; MFA; remote lock or wipe; backups.	2	5	10	High	Mitigate	Richard Vincent	Migrate business operations to dedicated, secured business devices.	1	5	5	Medium	Planned	Dedicated-device inventory, configuration checklist, encryption and update evidence, migration confirmation.
R-05	Website loss or failed migration	Website and online intake	Because the website is being migrated and end-to-end migration and restoration testing is not yet complete, a deployment, configuration, or data-loss event could interrupt online services and customer intake, resulting in lost enquiries, delayed service, and recovery work.	3	3	9	Medium	The existing website remained operational; website files and migration materials are available.	3	3	9	Medium	Mitigate	Richard Vincent	Complete the migration; test restoration; document the result and recovery steps.	2	3	6	Medium	In progress	Migration completion record, restoration-test result, screenshots, backup location, recovery procedure.
R-06	Temporary customer passcode exposure	Device repair and quality assurance	Because customer passcodes are sometimes recorded temporarily for authorized quality-assurance testing, the passcode could be viewed or retained by an unauthorized person, resulting in unauthorized device access and customer-data exposure.	3	4	12	High	Passcodes requested only when needed; documented passcode procedure; sole-operator access; secure device storage; paper records shredded immediately after testing.	2	4	8	Medium	Accept and monitor	Richard Vincent	Confirm passcode destruction on the repair record and retain the current handling controls.	2	4	8	Medium	Ongoing	Repair record with destruction confirmation; review after a missing record, access concern, complaint, or addition of workers.
R-07	Inadequate incident response	Security and privacy incident handling	Because the business has no formally documented incident-response procedure, a security or privacy incident could be handled inconsistently or too slowly, resulting in greater data exposure, weak evidence preservation, delayed notification, and prolonged disruption.	3	4	12	High	The owner is the clear decision-maker; MFA is used; customer-device and passcode procedures exist; business records can be restored.	3	4	12	High	Mitigate	Richard Vincent	Create an incident-response procedure covering identification, containment, evidence preservation, customer and insurer communication, recovery, documentation, and lessons learned.	2	3	6	Medium	Planned	Approved incident-response procedure, incident log template, notification contacts, completed tabletop exercise.
R-08	Cloud or payment-provider outage	Zoho, Cloudflare, GitHub, Stripe, domain and hosting services	Because the business depends on external cloud and payment providers, a provider outage or access failure could interrupt customer communication, website availability, records, or payments, resulting in delayed service and lost revenue.	3	3	9	Medium	Restorable business-record backups; access to website and repository files; multiple communication and payment options; provider-managed infrastructure.	2	3	6	Medium	Mitigate and partially transfer	Richard Vincent	Maintain backups and alternative contact and payment methods; retain recovery information; review provider terms and insurance coverage.	2	2	4	Low	Ongoing	Backup test, alternative contact and payment instructions, provider terms review, insurance record.
R-09	Payment fraud or account misuse	Payment processing and transaction records	Because payment accounts and integrations may be targeted or misused, an attacker or fraudulent customer could cause unauthorized transactions or disputes, resulting in financial loss, operational effort, and reputational harm.	3	3	9	Medium	Payment provider processes full card information; complete card numbers are not stored by the business; MFA; digital and physical transaction records.	2	3	6	Medium	Mitigate and partially transfer	Richard Vincent	Review activity; restrict integrations; verify unusual transactions; retain transaction records; follow provider dispute procedures.	2	2	4	Low	Ongoing	Payment-provider alerts, activity reviews, integration list, transaction records, dispute records.
R-10	Advisory services launched without minimum governance	Planned cybersecurity and secure-AI advisory services	If advisory services launch before scopes, information-handling rules, quality review, contract terms, human oversight, and professional limitations are established, inaccurate or insecure deliverables could be provided, resulting in client data exposure, disputes, reputational harm, or work outside the business's capability.	3	4	12	High	The services have not launched and no advisory-client information is being processed.	1	4	4	Low	Avoid until ready	Richard Vincent	Before launch, document service scope, client agreements, information handling, AI human review, secure storage, quality assurance, incident response, and professional limitations.	2	3	6	Medium	Not launched	Approved prelaunch checklist, service scope, agreement template, AI review procedure, secure-storage evidence, quality-review record.

The Phone Boss ULTD — Risk Treatment Plan

Target dates remain to be scheduled by the risk owner. Evidence must show that each action was completed and operates as intended.

Risk ID	Priority	Treatment	Action	Owner	Target date	Status	Expected evidence	Completion notes	Post-treatment rating
R-01	Medium	Accept and monitor	Record devices kept overnight and the reason; maintain current custody controls.	Richard Vincent	To be scheduled	Ongoing	Intake record, custody record, return receipt; review after loss, storage change, higher volume, or adding workers.		Medium
R-02	High	Mitigate	Verify unique passwords and recovery methods; review active sessions and integrations; remove unnecessary access; strengthen MFA where available.	Richard Vincent	To be scheduled	Planned	Password-manager review, recovery-method screenshots or exports, session review, integration inventory, MFA configuration evidence.		Medium
R-03	Medium	Mitigate	Create secure emergency instructions, an active-device and job inventory, customer-contact steps, and trusted-person authorization without informal password sharing.	Richard Vincent	To be scheduled	Planned	Continuity procedure, emergency contact authorization, active-job inventory, secure access-recovery instructions.		Medium
R-04	High	Mitigate	Migrate business operations to dedicated, secured business devices.	Richard Vincent	To be scheduled	Planned	Dedicated-device inventory, configuration checklist, encryption and update evidence, migration confirmation.		Medium
R-05	Medium	Mitigate	Complete the migration; test restoration; document the result and recovery steps.	Richard Vincent	To be scheduled	In progress	Migration completion record, restoration-test result, screenshots, backup location, recovery procedure.		Medium
R-06	Medium	Accept and monitor	Confirm passcode destruction on the repair record and retain the current handling controls.	Richard Vincent	To be scheduled	Ongoing	Repair record with destruction confirmation; review after a missing record, access concern, complaint, or addition of workers.		Medium
R-07	High	Mitigate	Create an incident-response procedure covering identification, containment, evidence preservation, customer and insurer communication, recovery, documentation, and lessons learned.	Richard Vincent	To be scheduled	Planned	Approved incident-response procedure, incident log template, notification contacts, completed tabletop exercise.		Medium
R-08	Medium	Mitigate and partially transfer	Maintain backups and alternative contact and payment methods; retain recovery information; review provider terms and insurance coverage.	Richard Vincent	To be scheduled	Ongoing	Backup test, alternative contact and payment instructions, provider terms review, insurance record.		Low
R-09	Medium	Mitigate and partially transfer	Review activity; restrict integrations; verify unusual transactions; retain transaction records; follow provider dispute procedures.	Richard Vincent	To be scheduled	Ongoing	Payment-provider alerts, activity reviews, integration list, transaction records, dispute records.		Low
R-10	Low	Avoid until ready	Before launch, document service scope, client agreements, information handling, AI human review, secure storage, quality assurance, incident response, and professional limitations.	Richard Vincent	To be scheduled	Not launched	Approved prelaunch checklist, service scope, agreement template, AI review procedure, secure-storage evidence, quality-review record.		Medium

Risk Assessment Methodology

Method: 5 × 5 qualitative assessment. Risk score = likelihood × impact. Ratings support prioritization and do not replace owner judgment.

Likelihood scale			Rating bands	
Score	Label	Meaning	Score	Rating
1	Rare	Not expected during the review period.	1–4	Low
2	Unlikely	Could occur, but is not expected during the review period.	5–9	Medium
3	Possible	May occur during the review period.	10–16	High
4	Likely	Expected to occur in many circumstances.	17–25	Critical
5	Almost certain	Expected to occur repeatedly or is already occurring.		

Impact scale			Risk terms			
Score	Label	Meaning	Term	Definition		
1	Insignificant	Minimal operational, financial, legal, or customer effect.	Inherent risk	Risk before considering existing controls.		
2	Minor	Limited disruption or cost; manageable through normal operations.	Residual risk	Risk remaining after current controls.		
3	Moderate	Noticeable service, financial, customer, or compliance impact.	Target risk	Expected risk after planned treatment is completed and verified.		
4	Major	Serious data, financial, legal, operational, or reputational impact.	Risk owner	Person accountable for monitoring, treatment, and acceptance.		
5	Severe	Potentially business-threatening, widespread, or highly damaging impact.	Acceptance authority	Richard Vincent, owner of The Phone Boss ULTD.		

Review requirement	Treatment options			
Review risks at least annually and after a security incident, major platform or supplier change, business-model change, new worker, material increase in customer-device volume, or launch of advisory services.	Option	Meaning		
A treatment is not complete until evidence confirms implementation and, where applicable, operating effectiveness.	Mitigate	Reduce likelihood or impact by implementing controls.		
The current register reflects owner-provided facts and stated practices. Items identified as not yet verified remain open treatment actions.	Avoid	Stop or delay the activity that creates the risk.		
Information classification: Internal business record.	Transfer	Shift part of the financial consequence through a provider, contract, or insurance; ownership remains with the business.		
Assessment owner: Richard Vincent.	Accept	Retain the risk within approved tolerance and continue monitoring.		
Review date: To be scheduled.				